

Fundamentals of Information Systems Security

Lab 3: Password Cracking with John the Ripper

Objective: Understand password security by using dictionary and brute-force attacks.

Prerequisites

- Kali Linux VM.
- John the Ripper (JtR) pre-installed.
- Wordlist: `/usr/share/wordlists/rockyou.txt` (unzip it first: `sudo gunzip /usr/share/wordlists/rockyou.txt.gz`).

Learning Objectives

By the end of this lab, you will be able to:

- Create password hashes using common algorithms (MD5, SHA).
- Use John the Ripper in dictionary mode.
- Use John the Ripper in incremental (brute-force) mode.
- Analyze the effectiveness of password strength.

Lab Steps

Step 1: Create a Sample Hash

Create a file named `hash.txt` containing a password hash.

Using `openssl` to generate a SHA-256 hash (or use `mkpasswd` for Linux hashes):

```
echo -n "mysecret" | sha256sum | awk '{print $1}' > hash.txt
```

Note: `-n` prevents a newline from being hashed.

Alternatively, for a more realistic Linux shadow hash:

```
mkpasswd -m sha-512 -S abcd "password123" > hash.txt
```

Step 2: Dictionary Attack

Run John the Ripper in dictionary mode:

```
john --format=raw-sha256 --wordlist=/usr/share/wordlists/rockyou.txt  
hash.txt
```

If you used the `mkpasswd` method, use `-format=sha512crypt`.

Show the cracked password:

```
john --show hash.txt
```

Step 3: Try a Stronger Password

Create a new hash for a complex password (e.g., `P@ssw0rd!#2024`) and repeat the dictionary attack.

Observation: It may fail to crack it if the password isn't in the wordlist.

Step 4: Brute-Force (Incremental) Mode

If the dictionary attack fails, try incremental mode:

```
john --incremental --format=raw-sha256 hash.txt
```

Press **Ctrl+C** to stop. John will save its progress. To show the cracked password after it finishes, use:

```
john --show hash.txt
```

Step 5: Cracking Multiple Hashes

Create a file with multiple hashes (password1, password2, etc.) and run John:

```
john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
```

John will automatically crack them in parallel.

Step 6: Using Custom Rules

John has rule sets to mutate words (e.g., adding numbers, capitalizing). Run:

```
john --rules --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

Deliverables

Submit a report containing:

1. The hashed password you generated.
2. The cracked password and the time taken.
3. A screenshot showing John successfully cracking the hash.
4. A brief analysis of why `rockyou.txt` is effective, and the importance of using passwords not found in dictionaries.
5. (Optional) Explain what "salting" is and how it affects cracking attempts.